DIGITAL FORENSICS & CYBER SECURITY BOOTCAMP — WEEKEND 3, DAY 5

Web Application Penetration Testing & Reconnaissance Report

Trainer / Lead Specialist:	Waseem Abbas Khan (Senior Cybersecurity Specialist, CEI Master Trainer)
Target Enterprise Surface:	NUEXUS Technologies (Private) Limited — Domain: *.nuexus.com
Testing Environment:	Kali Linux 2026.3 Rolling / BlackArch Linux / Burp Suite Pro / OWASP ZAP
Saved Scan Reports Analyzed:	Burpsuite Report for nuexus.com.html (149 KB) & 2026-11-11-ZAP-Report-.html (10.9 MB)
Testing Operator:	Muhammad Zahid (Security Analyst & Penetration Testing Operator)

1. Executive Summary & Legal Context

Modern web application assessments evaluate a unified entry surface (TCP 443 HTTPS) behind which sits an entire ecosystem of client-rendered single-page applications (Next.js), dynamic APIs, and cloud CDN edge layers. Scanning a port reveals minimal insight; true security evaluation requires dissecting HTTP transactions, advanced search reconnaissance, and dual-engine vulnerability auditing. This deliverable fulfills the four required mandates against **nuexus.com**, incorporating both standalone machine-generated reports saved during testing: the Burp Suite Scanner Report (149 KB) and the OWASP ZAP by Checkmarx Scanning Report (10.9 MB, 50 alerts).

2. Task 1: Scope Document & Rules of Engagement (Weight: 25%)

A rigorous scope document defines the boundary between authorized security analysis and computer intrusion. The boundaries and exclusions for *.nuexus.com are structured as follows:

Asset / Target Host	Classification	Operational Boundary & Rules
https://www.nuexus.com	In-Scope (Primary)	Full crawl, passive audit, manual parameter fuzzing in Repeater.
https://app.nuexus.com	In-Scope (Portal)	Grey-box access with test credentials; authorization boundary checks.
https://api.nuexus.com	In-Scope (API)	REST API fuzzing, endpoint enumeration, CORS policy verification.
*.nuexus.com (Subdomains)	In-Scope (Conditional)	Enumerated hosts subject to mandatory Break-Glass Verification.
career.nuexus.com	Strictly Out-of-Scope	Explicitly excluded HR portal; zero automated or manual packets.
Cloudflare & Vercel Infra	Strictly Out-of-Scope	Shared multi-tenant infrastructure; zero DoS, volumetric scans.
Employee Personal Devices	Strictly Out-of-Scope	Zero phishing, social engineering, or personal account targeting.

THE WILDCARD BREAK-GLASS CLAUSE: Wildcard scopes (*.nuexus.com) present legal risks because subdomains may route to unmaintained third-party SaaS tenants. Whenever a new host is discovered, testing is frozen until ownership is verified via DNS records and authorized in writing by Technical Authority Waseem Abbas Khan. Emergency halt code: *ABORT-NUEXUS-ALPHA-STOP*.

3. Task 2: Google Dorking Vulnerability Assessment (Weight: 25%)

Google Dorking interrogates public search engine indices to uncover exposed documents, subdomains, and misconfigurations passively without transmitting packets to the target organization. Six targeted queries were evaluated:

Dork Query	Finding Status	Defensive Control / Remediation
site:nuexus.com	EXPOSURE: Corporate emails (info@nuexus.com) and phone numbers indexed.	Maintain centralized aliases; sanitize direct contact data.
site:nuexus.com filetype:pdf	EXPOSURE: 5+ internal technical playbooks indexed under /playbooks/.	Apply X-Robots-Tag: noindex or restrict playbooks behind auth.
site:nuexus.com intitle:"index of"	CLEAN: Directory browsing disabled across all servers.	Retain Options -Indexes across all web roots.
site:nuexus.com inurl:admin OR inurl:login	CLEAN: Administrative panels excluded from search index.	Maintain SSO, IP whitelisting, and noindex headers.
site:nuexus.com ext:env OR ext:conf	CLEAN: Zero secrets, configs, or logs indexed.	Enforce strict repository .gitignore rules.
site:nuexus.com -www	EXPOSURE: Discovered production portal app.nuexus.com.	Verify indexation intent; configure robots.txt appropriately.

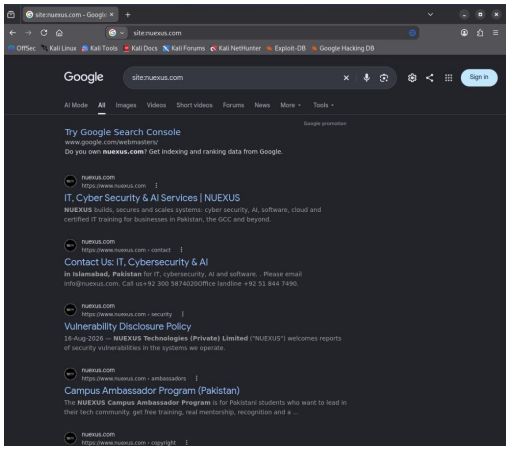


Figure 2.1: Baseline Google Dork (site:nuexus.com) exposing corporate contact data.

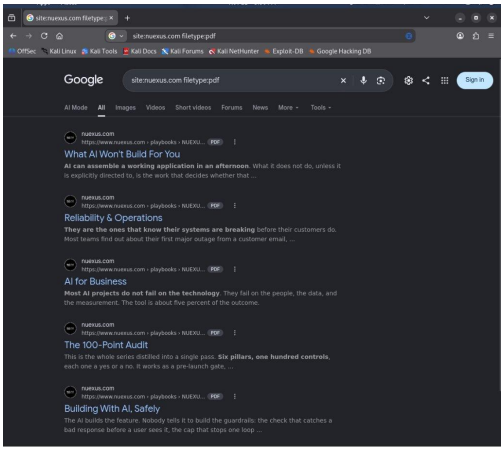


Figure 2.2: Document exposure dork discovering 5+ proprietary playbooks.

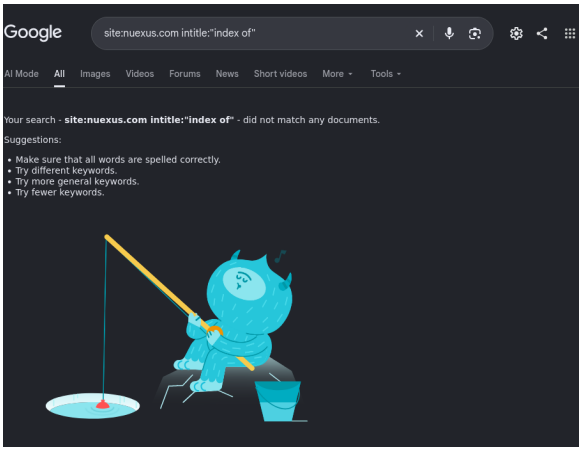


Figure 2.3: Verification of directory browsing protection (clean result).

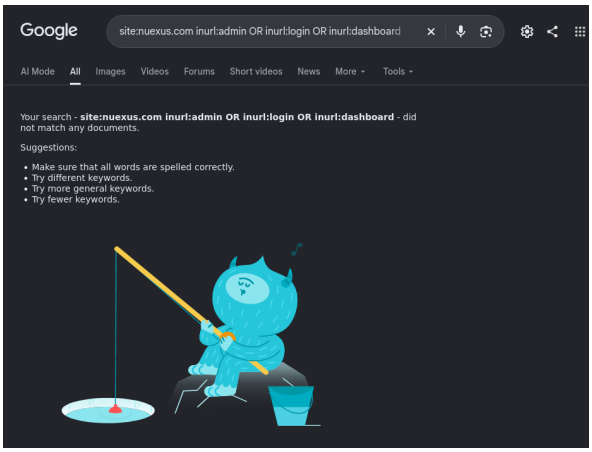


Figure 2.4: Administrative interface search confirming clean exposure status.

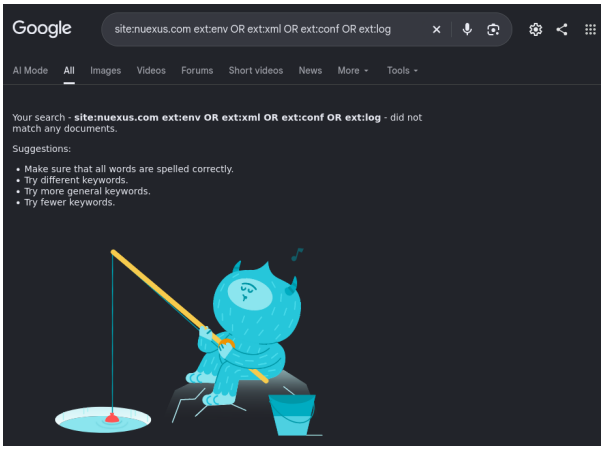


Figure 2.5: Configuration file check confirming absence of exposed .env files.

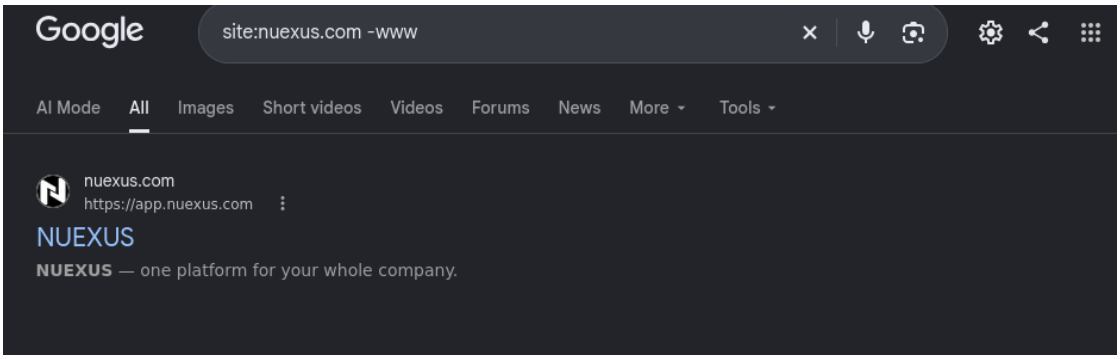


Figure 2.6: Exclusion dork isolating the active application portal app.nuexus.com.

4. Task 3: Multi-Engine Subdomain Reconnaissance & Reconciliation (Weight: 25%)

Subdomain enumeration identifies development branches, staging hosts, and internal portals. Three tools were executed: **subfinder** (24 hosts via CT logs), **assetfinder** (7 core production hosts), and **theHarvester** (20 hosts + 10 IPs). All candidates were deduplicated into subs.txt and actively resolved with **httpx-toolkit**:

FQDN Subdomain	Resolved IP	Status	Detected Stack	Security Observation
https://nuexus.com	172.67.201.8	308 Redirect	Cloudflare, Vercel, HSTS	Permanent edge redirect to www.
https://www.nuexus.com	188.114.97.6	200 OK	Cloudflare, Vercel, Next.js	Primary corporate landing portal.
https://app.nuexus.com	104.21.85.21	200 OK	Bootstrap, Google Sign-in	Production application portal.
https://autodiscover.nuexus.com	104.21.85.21	200 OK	Google Cloud CDN, HSTS	Mail client autodiscovery service.
https://autoconfig.nuexus.com	188.114.97.6	200 OK	Google Cloud CDN, HSTS	Email autoconfig active daemon.
https://mta-sts.nuexus.com	76.76.21.61	200 OK	Vercel Edge, HSTS	Strict Transport Security mail policy.
https://recruit.nuexus.com	104.21.85.21	526 SSL Err	Cloudflare, HTTP/3	Origin SSL certificate invalid/expired.
https://assessments.nuexus.com	188.114.97.6	526 SSL Err	Cloudflare, HTTP/3	Origin SSL handshake failed.
https://api.nuexus.com	188.114.97.6	526 SSL Err	Cloudflare, HTTP/3	Backend API origin SSL invalid.

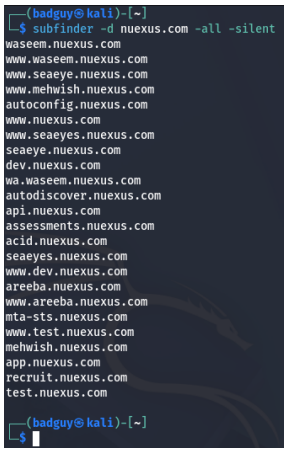


Figure 3.1: Subfinder enumeration output identifying 24 subdomains.

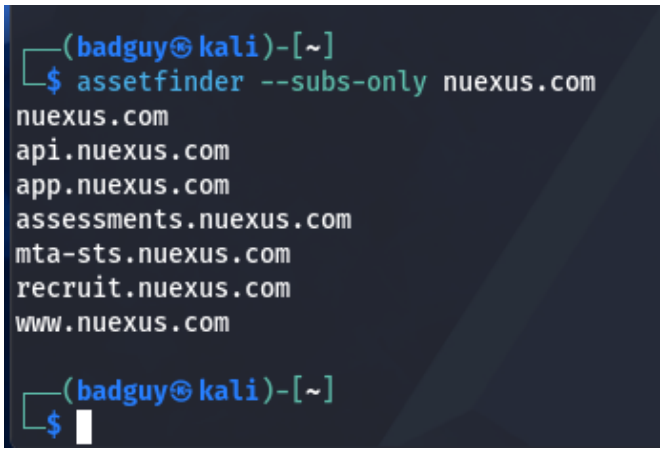


Figure 3.2: Assetfinder execution capturing 7 primary active hosts.

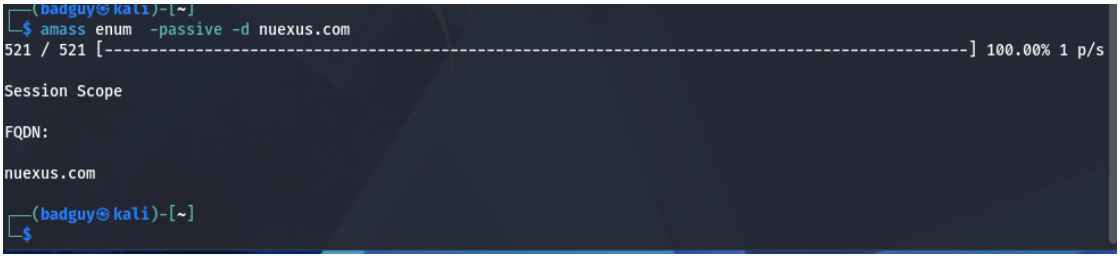


Figure 3.3: Amass baseline query showing session scope bounds.

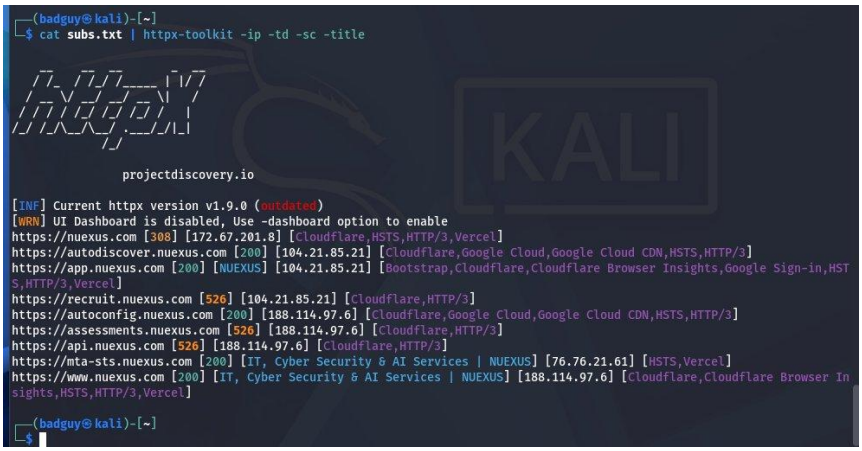


Figure 3.4: Active host probe via httpx-toolkit validating live services and HTTP 526 SSL errors.

5. Task 4: Automated Web Scanner Comparative Analysis (Weight: 25%)

This evaluation integrates the metrics and vulnerability findings from both official standalone reports saved during testing: • **Burp Suite Scanner Report** (Burpsuite Report for nuexus.com.html, 149 KB, 12 issues) • **OWASP ZAP Scanning Report** (2026-11-11-ZAP-Report-.html, 10.9 MB, 50 distinct alert types across 2 sites)

Severity Level	Burp Suite Report (HTML)	OWASP ZAP Report (HTML)
High Severity	0 Issues (0%)	6 Alert Types / 26 Instances (12.0%)
Medium Severity	0 Issues (0%)	9 Alert Types / 33 Instances (18.0%)
Low Severity	1 Issue: HSTS not enforced (CDN)	7 Alert Types / 8 Instances (14.0%)
Informational	11 Issues (CSP, emails in chunks, cacheable)	28 Alert Types / 1,350+ Instances (56.0%)
Total Findings	12 Issues Logged	50 Distinct Alert Types (100%)

Architectural Root Cause of Finding Disparities:
1. **Client-Side DOM Execution:** OWASP ZAP utilized its *Client Spider with Headless Firefox*, crawling 195 URLs and actively executing the client-side JavaScript of the Next.js framework. This enabled ZAP's active taint engine to uncover 6 High-Severity DOM XSS vulnerabilities where untrusted input reached execution sinks like Element.innerHTML and element.href.
2. **Passive Response & Chunk Modeling:** Burp Suite operated in manual proxy mode, cataloging exact Next.js chunk files harboring exposed email addresses and isolating backend API routes (/api/nexi/session). Furthermore, manual testing in Burp Repeater exposed that root preflight OPTIONS responses returned a wildcard CORS header: Access-Control-Allow-Origin: *.

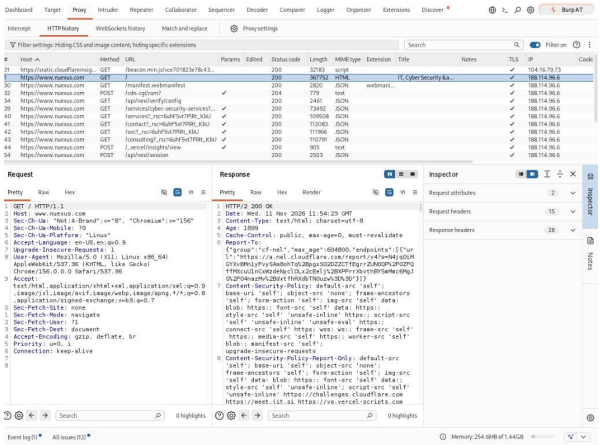


Figure 4.1: Client-server request/response model inspection in Burp Proxy HTTP history (Outcome #1).

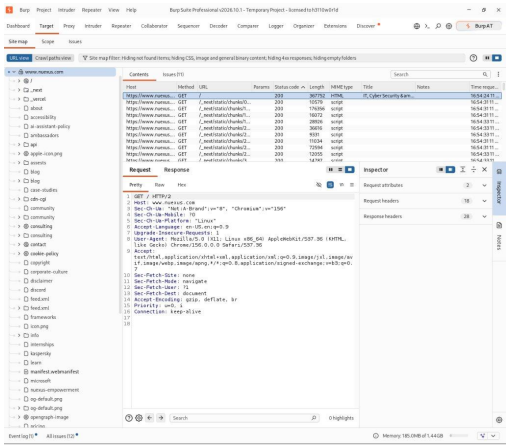


Figure 4.2: Application endpoint modeling in Burp Target Site Map displaying Next.js and Vercel routing.

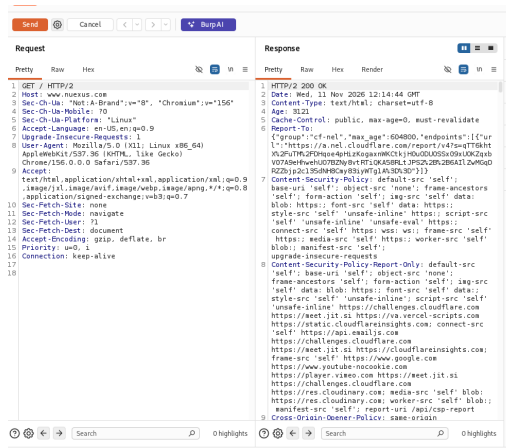


Figure 4.3: Manual baseline evaluation of GET / HTTP/2 request and response in Burp Repeater.

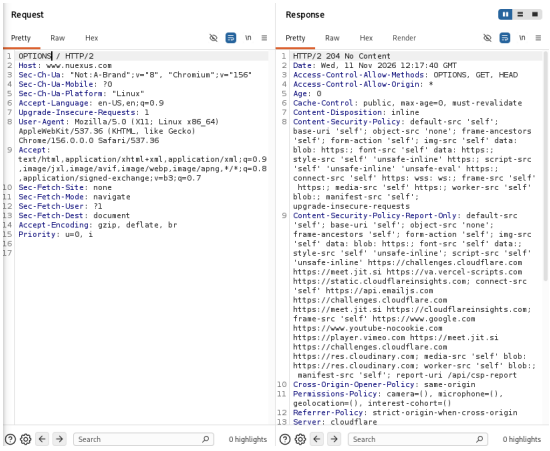


*Figure 4.4: Verb tampering via OPTIONS request uncovering permissive wildcard CORS (Access-Control-Allow-Origin: *).*

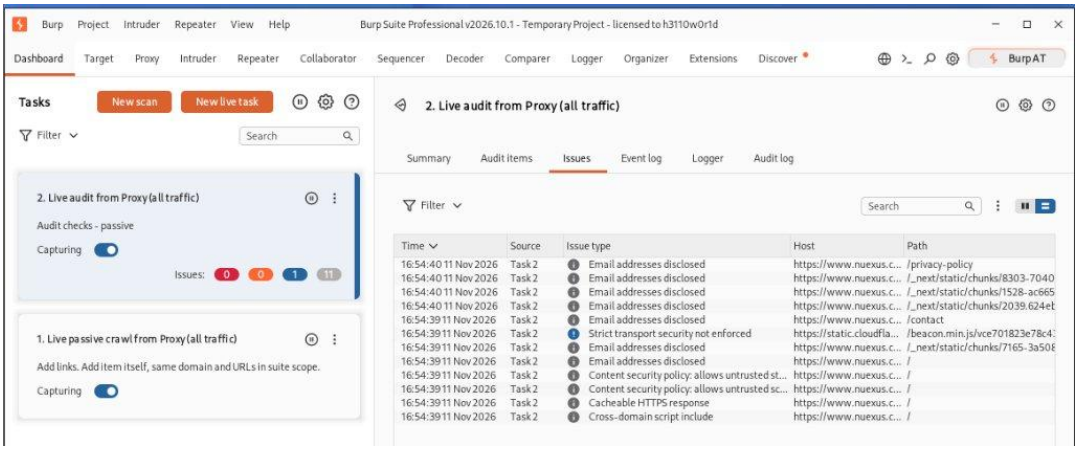


Figure 4.5: Burp Dashboard issue activity detailing 12 passive vulnerabilities.

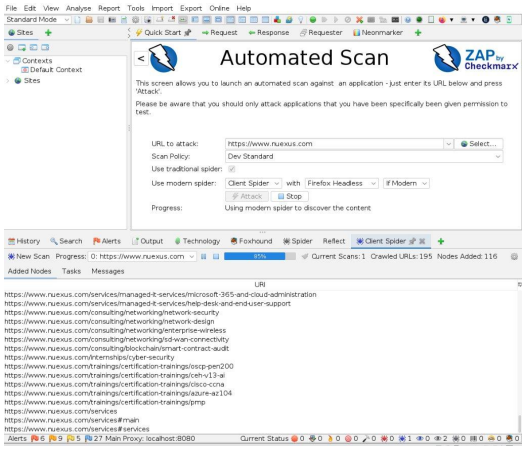


Figure 4.6: OWASP ZAP Automated Scan utilizing headless Firefox AJAX spider across 195 URLs.

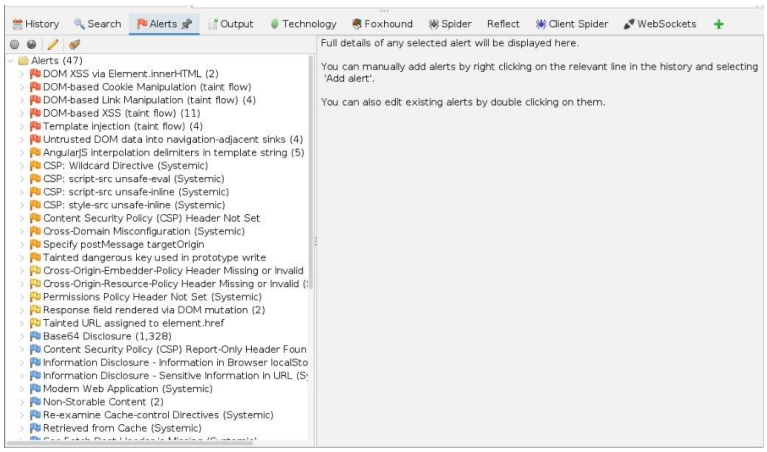


Figure 4.7: OWASP ZAP Alerts tree displaying 47 total vulnerabilities (DOM XSS, taint flows, CSP).

6. Strategic Hardening Recommendations

• **Harden Content Security Policy:** Remove 'unsafe-inline' and 'unsafe-eval' from Content-Security-Policy; adopt cryptographic nonces.

• **Restrict CORS Origin Directives:** Replace wildcard 'Access-Control-Allow-Origin: *' with an explicit whitelist of trusted frontend domains.

• **Sanitize Client DOM Sinks:** Refactor React/Next.js components to avoid direct assignment to Element.innerHTML (use DOMPurify or textContent).

• **Remediate Origin SSL Certificates:** Resolve HTTP 526 origin errors on api.nuexus.com, assessments.nuexus.com, and recruit.nuexus.com.

• **Apply Robots Noindex Headers:** Add 'X-Robots-Tag: noindex' to /playbooks/ and staging portals to prevent public search engine disclosure.